ONE-PAGE BRIEF

# Post-quantum cryptography review: cairo @ 68a61f6c6251

Client: StarkWare — public repository (passive review) · Source: github.com/starkware-libs/cairo, commit `68a61f6c6251` · Reviewed: 2026-10-28 12:22 UTC · Risk profile: Web3 project

POST-QUANTUM MATURITY

**Level 0 of 4**

no post-quantum cryptography

FINDINGS

**1** Critical **4** High **5** Medium **10** Low **4** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Signatures: 10 + 5 − 12 = 3 → **too late**

**Next step:** Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

## WHAT MATTERS MOST

| | |
|---|---|
| Critical<br>QSI-2026-04420 | **zip 0.6.6 is affected by RUSTSEC-2026-0369**<br>What to do: Upgrade to a fixed version (9.0.0). |
| High<br>QSI-2026-04406 | **pulldown-cmark 0.13.4 is affected by RUSTSEC-2026-0414**<br>What to do: Upgrade to a fixed version (0.13.5). |
| High<br>QSI-2026-04408 | **quinn-proto 0.11.17 is affected by RUSTSEC-2026-0340**<br>What to do: Upgrade to a fixed version (0.11.18). |
| High<br>QSI-2026-04409 | **quinn-proto 0.11.17 is affected by RUSTSEC-2026-0343**<br>What to do: Upgrade to a fixed version (0.11.18). |

16 more in the full report.

## WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

| Role | Algorithms | What to do |
|---|---|---|
| Medium transaction and message signing | ECDSA | Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum... |
| Medium role not determined | ECDSA | Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)... |

## KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 19; unlikely to apply to this build: 2 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 17.

Static review of source code and manifests; files analysed: 567. No requests were sent to the owner's systems.

Full report, content SHA-256: `18d87b68c3d7d5ee5324566405f8f401703b54def1529b72cf769a0cbf89aa4a`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.